

Per Bergstrand
Dataskyddsombud
Per.bergstrand@skane.se

Internt

Datum 2018-12-03
Version
Dnr

1 (13)

Juridisk bedömning kring överföring av information som omfattas av sekretess till en s.k. publik molntjänst (amazon web services, AWS)

1. Bakgrund

AWS utgör en plattform för lagring av data och miljö för drift av IT-tjänster. Det är en s.k. publik molntjänst vilket innebär att den geografiska platsen där lagringen av data och miljön finns är tekniskt ointressant. En publik molntjänst innebär kort sammanfattat att infrastrukturen bygger på virtualisering för möjliggörande till att flera kunder kan dela på samma dataresurser (servrar, brandväggar, administratörer etc.). Som kund innebär det en begränsad insyn i hur information hanteras vilket ställer högre krav på kravställning och uppföljning. Användningen av AWS som driftsmiljö för nästa generations journalsystem som Region Skåne upphandlat innebär att en oerhört stor mängd data med mycket känsliga uppgifter kommer att lagras i servrar tillhöriga AWS och hanteras inom AWS driftsmiljö. Tjänsten innebär således att uppgifter, som utgör personuppgifter såväl som uppgifter som omfattas av sekretess, överförs till denna publika molntjänst. Bedömningen i denna PM avser de juridiska frågeställningar som uppstår avseende röjandebegreppet i offentlighet- och sekretesslagen (OSL).

De IT-tjänster som denna PM berör avser såvitt kan bedömas i vart fall en tjänst för hantering av s.k. population health vilket inkluderar den totala mängden av patientjournaler för vilka Region Skåne ansvarar samt en stor mängd annan data som kan härledas till patient och hälsotillstånd. Därtill avses tjänsten även användas för lagringsplats från medicinskteknisk utrustning som patient själv förfogar över, t.ex. olika former av hälsoövervakning eller hälsomätning som patient förfogar över i hemmet. Det ska tilläggas att väldigt lite konkret information om vad tjänsten faktiskt ska innehålla för uppgifter har givits.

2. Publik molntjänst - överblick

En publik molntjänst kännetecknas av att flera kunder delar på samma infrastruktur och administreras av samma personal. Stora publika molntjänster som AWS kännetecknas också av att de är etablerade i ett stort antal länder och har en mängd

olika underleverantörer för att kunna hantera både tekniska och administrativ hantering av deras många kunders informationstjänster. Vanligtvis är det svårt för en kund att förhandla särskilda avtalsvillkor utan får utgå från det tjänsteutbud och de villkor som den stora molnleverantören levererar. Eftersom informationen och säkerheten måste vara mycket hög är det också vanligtvis svårt för enskilda kunder att få en inblick i hur säkerhet är uppbyggd eller tänkt att fungera. Globala molntjänstillhandahållare tillåter också sällan kunder att göra egna utvärderingar eller revisioner utan kund får istället åtkomst till delas av de revisioner och uppföljningar som bolaget självt genomför.

Sammantaget innebär det här att kund har förhållandevis få möjligheter att själv skapa sig en uppfattning av säkerhet eller upplägg utan får förlita sig på det som redovisas av leverantören.

3. Översiktlig teknisk beskrivning av kryptering och nyckelhantering

En inte obetydlig del av den juridiska diskursen avseende röjande avser kryptering och nyckelhantering. Här redogörs mycket kortfattat och övergripande för hur kryptering och nyckeltilldelning föreslagits hanteras inom AWS.

Lösningen som föreslås för kryptering och dekryptering av information är en standardlösning som AWS erbjuder till samtliga kunder. AWS nyckelhanteringslösning bygger en nyckelhierarki som även brukar benämnas som envelope encryption men som AWS har valt att kalla för Key Management System (KMS).

Enkel beskrivet så bygger KMS på att klartextnycklar för dekryptering skyddas genom att nyckeln i sig krypteras med en överliggande nyckel. Högst upp i denna hierarki finns det en nyckel som lagras i klartext och som kan anropas av underliggande nycklar för att en dekryptering ska kunna ske.

KMS är uppbyggt så att en huvudnyckel (den som finns högst upp i nyckelhierarkin) lagras i klartext på en så kallad Hardware Secure Module (HSM). HSM består av särskild hårdvara som är gjord för att hantera kryptografiska nycklar för att ge dem bästa möjliga skydd. Denna huvudnyckel ägs, administreras och sköts helt och hållet av AWS och kan (direkt eller indirekt) användas för att dekryptera de underliggande nycklarna i nyckelhierarkin.

När en kund väljer att använda sig av KMS så får denne en unik kundnyckel genererad som AWS benämner som Customer Master Key (CMK). Denna nyckel lagras hos kunden i flera lokationer krypterad av AWS HSM. D.v.s. det finns ingen direkt dedikerad hårdvara som skyddar nyckeln utan skyddet förlitas helt på krypteringen som görs av AWS HSM. Detta gör att nycklarnas tillgänglighet kan säkerställas.

I och med att AWS har åtkomst till och kan administrera nycklarna i AWS HSM och Cerner administrera nycklar inom CMK så har båda parterna praktisk möjlighet att bereda sig åtkomst till dekrypterad information och ta del av denna i klartext. Denna möjlighet är självklart tänkt att hanteras på ett strukturerat sätt och

under ordnade former, men det finns inget i lösningen som tekniskt omöjliggör för organisationerna att självmant ta del av kundens information.

Sammanfattningsvis kan sägas att kryptering som hanteras efter denna struktur ger ett gott skydd mot att information avslöjas för en helt utomstående aktör, men egentligen endast innebär en administrativ säkerhet från att leverantör själv tar del av kunds information.

4. Omfattas uppgifterna som överförs av EU:s dataskyddsförordning (nr 2016/679) (DSF)¹?

All slags information som direkt eller indirekt kan hänföras till en fysisk person som är i livet är enligt DSF att betrakta som personuppgifter. Även uppgifter som inte är direkt hänförliga till en individ, t.ex. uppgifter som pseudonymiserats (givits ett unikt löpnummer istället för individuppgifter såsom namn, personnummer, telefonnummer etc.) omfattas av begreppet personuppgifter.

Tveklöst kommer uppgifterna som ingår i tjänsterna ovan att innehålla oerhört stora mängder personuppgifter. Personuppgifterna avser sjukdomstillstånd, hälsoinformation, vidtagna medicinska åtgärder, planerade sådana samt en stor mängd mätinformation från medicinskteknisk utrustning. Dessa uppgifter är inte bara att betrakta som personuppgifter utan även känsliga sådana som är således är extra skyddsvärd och för vilka lagstiftningen ställer extra höga krav på.

5. Vad innebär en överföring till en extern leverantör juridiskt?

En överföring av personuppgifter till en extern leverantör innebär att Region Skåne, som är personuppgiftsansvarig enligt DSF men också ansvarig för all hantering av handlingar som omfattas av sekretess enligt OSL, låter en annan organisation ta över hanteringen av den information som Region Skåne bär det fulla ansvaret för. Det externa företaget är därmed enligt DSF att betrakta som ett s.k. personuppgiftsbiträde, dvs. en juridisk person som enbart på uppdrag av en personuppgiftsansvarig hanterar personuppgifter.

Det här innebär dock inte att Region Skåne på något sätt får ett mindre ansvar för hanteringen utan är tvärtom den part som fortfarande är huvudansvarig för hur uppgifterna hanteras. Eftersom ansvaret fortfarande ligger på Region Skåne måste Region Skåne se till att den hantering som sker av informationen uppfyller alla krav som DSF, OSL och annan relevant lagstiftning ställer.

¹ Populärt kallat GDPR (general data protection regulation)

6. Avgränsning av denna utredning

På uttrycklig begäran ska denna rättsliga analys *endast* avse möjligheterna att överföra information som omfattas av sekretess till en molnleverantör utifrån röjandeförbudet i OSL. Det kommer därför inte att närmare beröras vilka krav som ställs enligt DSF. Det ska dock understryka att DSF ställer krav inte bara av konkret art som att man måste upprätta ett personuppgiftsbiträdesavtal och informera alla registrerade utan även krav på processer som att det måste ske en riskanalys (s.k. konsekvensbedömning eller dpia) för att mer konkret bedöma vilka risker som finns och om det finns tillräckliga motåtgärder för att mitigera dessa risker. Om en risk fortfarande anses föreligga trots föreslagna motåtgärder finns dessutom en skyldighet att samråda med tillsynsmyndigheten på området (Datainspektionen). Förutom dessa lagstiftningar ställer även patientdatalagen (PDL) samt Arkivlagen krav på hur information i offentlig förvaltning inom ramen för hälso- och sjukvård ska hanteras. Oaktat föreliggande utredning finns alltså en mängd andra krav och frågor att ta ställning till.

7.1 Omfattas uppgifterna som lämnas ut till AWS av sekretess?

I OSL berörs myndigheters sekretess, där anges vilka uppgifter som hanteras inom offentlig förvaltning som trots huvudregeln om offentlighet inte alls ska vara offentliga utan istället hanteras med sekretess. Sekretess innebär ett förbud att röja uppgift för annan, vare sig det sker muntligen, skriftligen eller på något annat sätt, härav kommer det s.k. *röjandeförbudet*.

Huvudregeln om sekretess innebär att uppgifter i den offentliga hälso- och sjukvården om en patients hälsa eller personliga förhållanden inte får lämnas ut, om det inte är helt klart att uppgiften kan röjas utan att patienten eller någon närstående lider men (25 kap 1§ offentlighets- och sekretesslagen, OSL).

Bestämmelsen har ett s.k. omvänt skaderekvisit, dvs. det måste vara helt klart att uppgiften kan röjas utan att något men (någon skada) uppstår för att så ska kunna ske. Detta är en väldigt stark sekretessgrund och föranleder således också att uppgiften måste skyddas på ett säkert sätt.

Sammanfattning om uppgifterna omfattas av sekretess

Merparten av informationen som föreslås lämnas ut till AWS omfattas av sekretess enligt bestämmelsen i 25 kap. 1 § OSL. Denna sekretess har ett s.k. omvänt skaderekvisit och är således en mycket stark sekretess.

7.2 Innebär en överföring av information ett utlämnande?

Ett överförande av uppgifter från en myndighet till en extern leverantör kan innebära att uppgifterna anses vara *utlämnande* enligt Tryckfrihetsförordningen (1949:105) (TF), dvs. lämnat myndighetens sekretessområde. Om uppgifterna därtill anses omfattas av sekretess enligt Offentlighet och sekretesslagen

(2009:400) (OSL) får ett sådant utlämnande endast ske om det är tillåtet enligt OSL att röja uppgifterna för en utomstående part.

Sammanfattning om utlämnande

Eftersom en överföring av information till en extern leverantör de facto innebär att personal utanför den egna myndigheten kan ta del av informationen kan detta också innebära att informationen anses vara utlämnad till den mottagande organisationen.

7.3 Röjandebegreppet

Av 2 kap. 1 § OSL följer att det är förbjudet för myndigheter och för vissa uppräknade personer, som har tystnadsplikt, att röja eller utnyttja uppgifter som är sekretessbelagda enligt offentlighets- och sekretesslagen. Innebörden av att röja en uppgift kan kopplas till definitionen av begreppet sekretess i 3 kap. 1 § OSL, vilka sekretessen gäller mot enligt 8 kap. 1 § OSL och rekvisiten i 20 kap. 3 § brottsbalken (BrB) om brott mot tystnadsplikten. Förbudet att röja en uppgift gäller oavsett om uppgiften i fråga förekommer i en allmän handling eller inte. Högsta domstolen har i ett rättsfall gått närmare in på vad som krävs för att en uppgift ska anses vara röjd.² HD uttalade att uttrycket ”röjer uppgift” enligt vanligt språkbruk innebär att en uppgift avslöjas eller uppenbaras.

Detta förutsätter att det finns någon person, för vilken uppgiften görs tillgänglig. Det torde dock inte alltid kunna krävas att denne faktiskt har fått kännedom om uppgiften. Det bör sålunda som regel vara tillräckligt att en handling med sekretessbelagda uppgifter har kommit i någon obehörigs besittning. Även vissa andra närliggande situationer bör omfattas. Däremot kan inte varje möjlighet att ta del av en uppgift, som har beretts någon obehörig, medföra att uppgiften i sig ska anses ha röjts. Avgörande för straffansvar bör främst vara om uppgiften har blivit tillgänglig för någon under sådana omständigheter, att man måste räkna med att den obehörige kommer att ta del av uppgiften.

Det bör avslutningsvis även påpekas att det som är avgörande för straffansvar inte nödvändigtvis har samma betydelse för att avgöra om en handling har röjts utifrån OSL. Ett röjande utifrån OSL torde ha en mindre snäv tolkning än bedömning av straffansvar enligt BrB.

² NJA 1991 s. 103

Sammanfattning om röjandebegreppet

Röjandebegreppet innebär att en uppgift avslöjats för en obehörig mottagare. I begreppet torde innebära att det måste finnas någon sannolikhet att mottagaren tagit del av informationen. Att överföra uppgifter till en utomstående aktör för att denna på olika sätt ska hantera uppgifterna torde kunna omfattas.

7.4 Innebär ett överförande av information till en molntjänst ett utlämnande (och därmed potentiellt ett röjande) i lagens mening?

När det gäller behandling av personuppgifter av ett personuppgiftsbiträde kan ifrågasättas om denna överföring överhuvudtaget innebär ett utlämnande i OSL:s mening eftersom uppgifterna fortfarande omfattas av den personuppgiftsansvariges ansvar. Det har dock ansetts av JO³ att uppgifter som överförs till ett personuppgiftsbiträde visst ska anses röjt när de överlämnas till denne och att det därför måste finnas tillämpliga sekretessbrytande bestämmelser. JO ansåg i det angivna ärendet att det inte var tillåtet att använda sig av personuppgiftsbiträden som endast bands av avtalsreglerade tystnadsplikten (i motsats till hälso- och sjukvårdens genom lag straffbelagda tystnadsplikt) när det handlade om känsliga uppgifter som omfattades av sekretess och att uppgifterna därför röjts på ett sätt som inte tilläts enligt OSL.

Sammanfattning om överlämnande av uppgifter till molntjänst är ett utlämnande

Överföring av uppgifter till ett personuppgiftsbiträde kan anses vara utlämnade till detta biträde i rättslig mening. Det kan finnas undantag, som t.ex. hantering enbart för ”teknisk lagring”.

7.5 Är enbart ”teknisk lagring” ett utlämnande?

Enligt 2 kap. 6 § andra stycket tryckfrihetsförordningen (TF) anses en upptagning inkommen till myndighet när annan gjort den tillgänglig för myndigheten med tekniskt hjälpmedel som myndigheten själv utnyttjar för överföring i sådan form att den kan läsas, avlyssnas eller på annat sätt uppfattas. Av tredje stycket i samma paragraf framgår dock att en handling som återkommer till en myndighet efter teknisk bearbetning eller teknisk lagring inte anses som en inkommen handling. Rimligen bör det ursprungliga exemplaret då inte heller anses vara expedierat från, och därmed inte en upprättad allmän handling hos, den avsändande myndigheten. En annan tolkning skulle leda till att undantaget i 2 kap. 6 § 3 stycket TF helt skulle

³ Se beslut från JO 2015/16 s 606, med diarienummer 3032-2011, angående vårdgivares utlämning av patientuppgifter till personuppgiftsbiträden vid hjälp med journalskrivning.

förlora sin funktion, i vart fall då fråga är om enbart teknisk lagring utanför myndigheten.

En tolkning enligt ovan ger vid handen att en myndighet som uppdrar åt en molntjänstleverantör att enbart tekniskt lagra eller tekniskt bearbeta viss information inte anses ha expedierat handlingar i tryckfrihetsförordningens mening. En handling som inte är allmän hos den avsändande myndigheten blir således inte att betrakta som allmän bara för att den överlämnas till en molntjänstleverantör för teknisk bearbetning.

Det kan inledningsvis konstateras att det råder oenighet om hur bedömningen av denna regel ska tillämpas på molnleverantörer och om det överhuvudtaget är möjligt att enbart tekniskt lagra eller bearbeta information utan att det samtidigt innebär att informationen faktiskt också avslöjas för mottagaren. Här måste också uppmärksammas på att en molnleverantör knappast är ett enhetligt begrepp. Desto mer involverad leverantören är i hanteringen av själva informationen, i motsats till den rena lagringen av densamma, desto troligare är det också att en bedömning skulle vara att undantaget i 2 kap 6 § 3 st TF inte kan var tillämpligt. Molntjänster är tekniskt komplicerade vars själva natur bygger på att leverantören övertar en stor del av beställarens behov av teknisk infrastruktur och IT-kunnig personal för hantering av informationsmängderna. Det ligger således i sakens natur att desto mer av hanteringen som övertas av leverantören, desto mer involverad blir leverantören i hanteringen av informationen och anses således och tillhandahålla något mer än enbart en teknisk lagring.

Med beaktande av den mycket stora mängd information som omfattas av sekretess och dess synnerliga känslighet bör Region Skåne utgå från att undantaget för s.k. teknisk lagring inte ensamt är tillräckligt för att motivera en överföring.

Sammanfattning om s.k. teknisk lagring

Om en leverantör av en IT-tjänst är en myndighet och hanterar information enbart för att tekniskt lagra denna kan det vara att betraktas som att informationen fortfarande är i den ansvariga myndighetens besittning och alltså inte har lämnats ut. En liknande bedömning har enligt doktrin ansetts kunna ske även om leverantören är en privat organisation. En fullt utvecklad molnleverantör är dock oftast mer involverad i hanteringen av informationen och omfattas sannolikt inte av begreppet ”enbart teknisk lagring”.

7.6 När kan uppgifter som omfattas av sekretess lämnas ut?

Om situationen bedöms vara sådan att den ansvarige myndigheten anses ha lämnat ut uppgifter till en leverantör, måste myndigheten ha någon sekretessbrytande regel att falla tillbaka på. Fråga är då om den generella regeln i 10 kap 2 § OSL kan användas. Där anges att sekretess inte hindrar att en uppgift lämnas till en enskild eller till en annan myndighet, om det är nödvändigt för att den utlämnande myndigheten ska kunna fullgöra sin verksamhet. I betänkandet SOU 2014:39 angavs att något hinder för en myndighet att i avtal om leverans från en privat leverantör ta in en klausul om tystnadsplikt inte finns och att ett utlämnande till den

som tillhandahåller tjänsten vanligtvis kan ske med stöd av 10 kap 2 § OSL.⁴ Denna bedömning får dock anses som mycket tveksam när det gäller uppgifter i stor mängd som därtill omfattas av sekretess med omvänt skaderekvisit. Därtill får anses att ovan nämnda JO-beslut och utredning från Pensionsmyndigheten samt nu senast Setterwall Advokatbyrås utredning⁵ ytterligare försvagar slutsatsen att ett massutlämnande av uppgifter som omfattas av sekretess kan ske enbart med en hänvisning till 10 kap 2 OSL och en garanti om att molnleverantören ska förse sin personal med civilrättslig tystnadsplikt.

Som redogjorts för ovan så har Pensionsmyndigheten⁶ i en utredning bedömt att det alltid är olämpligt att lämna ut sekretessreglerade uppgifter till en molntjänstleverantör om inte en effektiv kontroll av leverantören kan garanteras. Att en leverantör använder många underbiträden samt att leverantören befinner sig i ett annat land är sådana aspekter som försvårar kontroll. Är detta ett faktum måste alltså ytterligare säkerhetsåtgärder tillkomma för att en överföring ska anses lagligt möjlig. Säkerhetsåtgärderna måste vara införda på ett sådant sätt att uppgifterna inte anses vara röjda för biträdet. Antingen kan den personuppgiftsansvarige se till att informationen är krypterad, dvs. *det är inte längre möjligt* för molnleverantören att ha åtkomst till informationen eller också kan den personuppgiftsansvarige se till att molnleverantören själv krypterar informationen *under förutsättning att den ansvarige myndigheten även då har kontroll* över vilka som kan se informationen.

Ett annat sätt vore att pseudonymisera informationen, dvs. ersätta alla uppgifter som direkt härleder en uppgift till en viss individ med ett löpnummer. Först när det är känt vilket löpnummer som hör till vilken person kan uppgifter i sig härledas till denne person. Med en sådan åtgärd skulle man kunna påstå att informationen inte är röjd förrän det tillfälle då personuppgiften är direkt hänförlig en individ. Frågan är dock i vilken utsträckning detta är görligt när det gäller stora informationsmängder av väldigt varierad art.

Möjligen kan alltså information anses vara icke röjd i juridisk mening trots att den överlämnats till annan part om man med olika åtgärder kan göra det tillräckligt sannolikt att den mottagande parten inte tar del av själva innehållet i informationen. I sådant fall skulle ett röjande undvikas och därmed inte kräva någon men-/skadeprövning enligt OSL. Bedömningen förutsätter att det enbart handlar om lagring och administration av uppgifterna samt att dessa kan hållas spärrade utan reell åtkomst för molntjänstleverantör. Slutsatsen förutsätter att denna lösning är

⁴ SOU 2014:39 Så enkelt som möjligt för så många som möjligt: Bättre juridiska förutsättningar för samverkan och service

⁵ På uppdrag av SKL gjorde Setterwalls Advokatbyrå oktober 2018 en utredning ”Frågor om röjande vid användning av molntjänster”

⁶ Se pensionsmyndighetens rapport <http://www.samradsgruppen.se/web/index.php/8-nyheter/151-molntjanster-ny-rapport>

tekniskt möjlig och det får samtidigt framhållas att denna legala möjlighet är obeprövad.⁷

Sammanfattning sekretess och röjande

Om uppgifterna omfattas av sekretess är det enligt offentlighet- och sekretesslagen (OSL) förbjudet att röja dessa uppgifter för utomstående. Det torde vara mycket svårt att på laglig grund kunna genomföra en massutlämning av sekretessbelagd information enbart med hänvisning till att det är nödvändigt för den utlämnande myndigheten att fullgöra sin verksamhet (vilket annars kan vara en sekretessbrytande grund).

En överföring av sekretessbelagda uppgifter till en molnleverantör kan alltså utgöra ett otillåtet röjande av sekretessbelagda uppgifter. Röjandet kan dock undvikas om den personuppgiftsansvarige ser till att biträdet inte någon har reell möjlighet till att ta del av uppgifterna. Ett sätt att möjliggöra detta är att kryptera uppgifterna, vilket då skulle förutsätta att biträdet själv saknar åtkomst till krypteringsnycklarna. Ett annat sätt skulle kunna vara att pseudonymisera samtliga uppgifter, vilket skulle förhindra biträdet till att ta del av uppgifterna i klartext. Detta under förutsättning att det är själva kopplingen till individerna som omfattas av sekretess.

En kombination av alla tre metoderna, dvs. tystnadspliktsavtal, kryptering och pseudonymisering torde sammantaget kunna anses uppnå en effekten att molnleverantören i praktiken inte har åtkomst till individuppgifterna och således att uppgifterna inte ska anses vara röjda för dem. Det får dock framhållas att det saknas praxis på området och att slutsatsen därmed är osäker. I nästa avsnitt berörs kryptering som lösning.

7.7 Innebär den kryptering som föreslagits att informationen inte är röjd?

I enlighet med stycket ovan, samt en lösning som rekommenderas i många utredningar, senast i Setterwalls Advokatbyrås utredning är att den ansvarige myndigheten förbjuder leverantören att ta del av informationen. Detta förbud kan säkerställas genom att kryptering av informationen sker vilket innebär att det rent tekniskt inte är möjligt att ta del av informationen om man inte har en digital nyckel för att låsa upp informationen.

Kryptering är alltså en lösning som kodar information till oigenkännlighet för alla som försöker ta del av den utan tillgång till rätt nyckel. Det avgörande i

⁷ Se även uttalande från e-samverkansgruppen om röjandebegreppet;
<http://www.esamverka.se/download/18.7e784787153f0f33aa51c84f/1464274177874/R%C3%A4ttsligt+uttalande+r%C3%B6jandebegreppet.pdf>

bedömningen blir således dels vilka som har tillgång till en sådan nyckel och dels under vilka omständigheter som informationen, trots kryptering, visas i klartext.

I avsnitt ovan har den krypteringslösning som föreslagits av AWS beskrivits.

En krypteringslösning är naturligtvis ett mycket bra skydd mot utomstående hot, alltså att informationen inte ska kunna fångas upp av aktörer som vare sig tillhör leverantör eller kund av en molntjänst. Men för att en krypteringslösning ska kunna innebära att informationen inte anses vara röjd för molnleverantören själv måste den rimligen innebära att denna aktör i praktiken till övervägande del förvägras möjlighet att ta del av informationen i klartext.

Det behöver kanske inte vara helt omöjligt men det måste göra tillräckligt sannolikt att ingen åtkomst de facto sker obehörigen. För att kunna uppnå detta påverkar en rad olika faktorer. En av dessa faktorer är krypteringslösningen, andra faktorer är a) möjligheterna till åtkomst är begränsad till ett fåtal personer b) möjlighet till åtkomst går att följa upp c) kund måste kunna få en insyn i hur detta sker samt även d) en praktiskt möjligt att själv ta del av sådana uppföljning samt e) insyn i hur behörigheter till ovanstående möjligheter administreras. En viktig del skulle också kunna vara att kund själv utgör själv en del av den administrativa kedjan som måste föregå ett upplåsande av krypteringen.

Sammantaget innebär den föreslagna lösningen att kryptering uppnås. Men inte att möjligheten till åtkomst för den egna organisationen (vare sig molntjänsteleverantören ASW eller leverantören av själv IT-tjänsten Cerner) omöjliggörs. Mer exakt hur begränsad möjligheten för dessa organisationer är och på vilket sätt Region Skåne kan ges insyn i hur krypteringsnycklarna i praktiken används, om så ens är praktiskt möjligt, har vi inte någon omfattande information om.

Sammanfattning bedömning om informationen ska betraktas som röjd utifrån leverantörens åtkomst

Slutsatsen torde vara att det inte kan betraktas som osannolikt att anställda hos leverantör kan ta del av informationen i tjänsten, och därmed också att informationen sannolikt är att betrakta som röjd om den överförs. Det torde i vart fall vara en stor risk för att denna bedömning infaller om inte Region Skåne kan ges en betydligt starkare kontroll över tillgången till den egna informationen.

8 Röjande utifrån annan stats möjlighet till insyn

Ovan har i princip endast redogjorts för röjanderisk avseende molnleverantören och dennes personal. Något som inte berörts ovan är därmed röjanderisk vad avser *annan stats insyn* i information.

Eftersom informationen kan vara åtkomlig från samtliga länder som den globala aktören är verksam i innebär det också att samtliga av dessa länders lagar och regler som legal åtkomst potentiellt kan bli tillämpliga.

Internationell rättslig hjälp i brottmål är sådana åtgärder som åklagare och domstolar under förundersökning och i rättegång i brottmål behöver bistånd med från en annan stat. Exempel på sådana åtgärder är förhör under förundersökning eller rättegång samt beslag och husrannsakan. Internationell rättslig hjälp är den väg en stat normalt har att gå enligt folkrätten för att få del av elektronisk bevisning från andra stater när det gäller innehåll i molnkonton, e-post och liknande. Alltså att det land som vill ta del av information som finns lagrad i ett annat land vänder sig till detta lands myndigheter för att få hjälp att få ut informationen.

Ett intensivt regelarbete pågår emellertid i många stater för att förändra detta och rättsläget får därför betraktas som minst sagt osäkert. Det förekommer att företag enligt den rättsordning som gäller i ett annat land är skyldiga att under vissa förhållanden lämna information till en myndighet i det landet utan att frågan hanteras genom internationellt samarbete mellan berörda länder. Som exempel kan nämnas den reglering som innebär att amerikanska myndigheter ska ges tillgång till information som lagras utomlands och att amerikanska tjänsteleverantörer av det skälet inte kan vägra att lämna ut sådan information (den s.k. CLOUD Act). Det är alltså inte längre avgörande var informationen rent fysiskt är lagrad utan risken för röjande av denna sort finns i alla länder där leverantören är etablerad och informationen är åtkomlig från. En amerikansk etablerad leverantör kan alltså vara tvungen att lämna ut information som begärs av amerikanska myndigheter oaktat att denna information fysiskt är lagrad inom EU och oaktat att leverantören avtalat om tystnadsplikt med ägaren av informationen.

Det här innebär alltså i praktiken att information från svenska myndigheter och företag som lagras i molntjänster som tillhandahålls av amerikanska företag kan bli direkt åtkomliga för amerikanska myndigheter utan att någon formell begäran sker till svenska myndigheter. Om det amerikanske företaget har faktiskt kapacitet (t.ex. möjlighet att låsa upp krypterad information, även om denna möjligheten är administrativt begränsad) kan företaget knappast vägra en begäran om utlämnande från en amerikansk myndighet.

Enligt eSams juridiska expertgrupp ska sekretessreglerade uppgifter anses bli röjda om de lämnas till ett företag som omfattas av en förpliktelse av beskrivet slag.⁸

Sammanfattning andra staters möjlighet till insyn

Det pågår internationellt en utveckling mot ett håll som innebär att stater vill ha möjlighet till direkt åtkomst för sina myndigheter till information redan om den åtkomsten är möjlig för företag etablerade i landet. De traditionella vägarna att vända sig till andra staters myndigheter förbigås under sådana omständigheter helt. Det innebär i praktiken att det är mycket svårt för en kund att avgöra risken för

⁸ Se eSams rättsliga utlåtande den 23 oktober 2018, <http://www.esamverka.se/stod-och-vagledning/rattsliga-uttalanden/rojande-och-molntjanster.html>

myndigheter i helt andra länder och rättsordningar kan ta del av information som överlåts till molnaktörer som har någon slags närvaro i dessa länder.

9.1 Sammanfattande bedömning

Sammanfattningsvis kan nämnas följande. Informationen som avses överföras till en molntjänst är dels mycket omfattande och dels av synnerlig känslig natur. Det är också okänt mer precist vilken information som kommer att omfattas av en överföring, ingen informationsklassning eller analys av informationsmängd har ännu genomförts.

Sammanfattningsvis kan konstateras att de juridiska möjligheterna att använda en leverantörs molntjänst i samband med lagring av sekretessbelagda uppgifter är begränsade och att en överföring av sekretessbelagda uppgifter till en molntjänstleverantör mycket väl kan utgöra ett otillåtet röjande av uppgifterna.

AWS är en molnleverantör av global natur vars verksamhet bygger på att företaget är etablerat i ett stort antal länder och att verksamheten också finns fördelad mellan dessa länder för att möjliggöra en 24/7 service. AWS är också en global aktör på så sätt att de avtal och villkor som leverantören nyttjar är skrivet för att användas i större sammanhang och det finns således små möjligheter att påverka för en enskild kund. Av liknande anledningar är möjligheterna för kunderna att själva få insyn och vidta inspektioner av säkerhetslösning mycket begränsade, man är som kund hänvisad till de rapporter och uppföljningar som AWS själva utför, låt vara av en utomstående aktör. Som kund har man således mycket begränsade möjligheter att påverka lösningen.

Redan av den anledningen är det enligt undertecknads uppfattning en stor risk att informationen är att betrakta som röjd om den överförs till en molntjänstleverantör som har faktiskt kapacitet att ta del av informationen och där Region Skåne som kund har mycket begränsade möjligheter till uppföljning av hur denna kapacitet nyttjas.

Därtill kommer den legala utveckling som innebär att andra staters rättskipande myndigheter och underrättelsetjänst ges möjlighet att begära åtkomst till informationsmängder från i det landet etablerade företag oavsett var informationen finns lagras och vem den tillhör. Om ett utländskt företag får den typ av beslut riktade mot sig från den inhemska myndigheten och företaget har faktiskt kapacitet att ta del av informationen finns knappast någon möjlighet för företaget att välja att inte lämna ut den. Denna risk har också av eSam ansetts innebära att information i sådana fall får betraktas som röjd.

Den sammantagna bedömningen utifrån en juridisk synpunkt är att det är en mycket stor risk att informationen som överförs till AWS publika molntjänst och som omfattas av sekretess kommer att betraktas som röjd.

9.2 Sammanfattning utifrån undertecknads roll som dataskyddsombud

Undertecknad vill dessutom i egenskap av dataskyddsombud understryka att bedömningen här enbart gällt hanteringen av information utifrån OSL. Det finns därtill stora utmaningar vad gäller behandlingen av den stora mängd personuppgifter som informationen utgör i förhållande till DSF (GDPR).

Undertecknad vill avslutningsvis understryka att detta uttalande inte berör lämpligheten med att använda sig av molntjänster i sig utan endast om några direkta juridiska förbud mot det kan anses föreligga. Det är min uppfattning i egenskap av dataskyddsombud att en åtgärd av en så pass strategisk art kring hanteringen av stora och viktiga informationstillgångar ska tas i ett större sammanhang.

10 Konsekvenser vid otillåtet röjande

Om Region Skåne anses ha röjt informationen utan att ha någon sekretessbrytande regel att falla tillbaka på kommer sannolikt regionen anses ha hanterat uppgifterna som omfattas av sekretess på ett otillåtet sätt.

Konsekvenserna som kan uppstå är en omfattande medial bevakning av detta faktum. Patienters förtroende för Regionens förmåga att hantera uppgifter på ett säkert sätt skulle kunna skadas i mycket hög grad. Även om Regionen anser sig ha väl avvägda skäl för att välja olika tekniska lösningar kan det komma att bli mycket svårt att kommunicera dessa.

Vidare kan ett brott mot DSF innebära att datainspektionen riktar tillsyn mot Region Skåne vilket kan resultera i administrativa sanktionsavgifter på upp till 10 miljoner kronor per tillfälle. De registrerade har också enligt DSF rätt till skadestånd om deras personuppgifter hanterats i strid med lagstiftningen på ett sätt som lett till skada för dem. Här ska dock noteras att DSF inte varit föremål för utredning i denna PM.

Rent straffrättsligt har tidigare ansvarig generaldirektör på Transportstyrelsen godtagit ett strafföreläggande för vårdslöshet med hemlig uppgift där en del av gärningsbeskrivningen var att hemliga uppgifter röjts till följd av oaktsamhet. Eftersom generaldirektören godtog strafföreläggandet har ingen domstol prövat frågan.

Det ska också påpekas att en återgång, alltså att välja en annan lösning efter att information redan överförts, kan vara en mycket komplicerad och kostsam process, något som inte minst har visat sig när Transportstyrelsen valde att frånträda den kritiserade IT-lösningen.